

한국에너지공단 상임감사

현 지 조 치

제 목 개인정보보호 관리 미흡

소 관 부 서 광주전남지역본부

조 치 부 서 광주전남지역본부

내 용

1. 업무개요

공단은 「국가 정보보안 기본지침」 및 「개인정보보호법」에 따라, 공단의 정보보안 및 개인정보보호 업무에 필요한 세부사항을 규정하기 위해 「정보보안 세부지침」 및 「개인정보 보호 내부 관리계획」을 제정·운영하고 있으며, 이와 관련하여 광주전남지역본부는 지급받은 PC로 분장된 업무를 수행하면서, 공단의 업무정보 및 개인정보 등이 유출되지 않도록 보안을 철저히 하고 있다.

2. 관련규정 및 판단기준

「정보보안 세부지침」 제73조에 따르면 개별사용자는 공단에서 지급받은 PC·노트북·휴대폰 등 단말기(이하 “단말기”라 한다) 사용과 관련한 일체의 보안관리 책임을 지며, 각종 비밀번호 변경사용, 최신 보안패치 유지, 불필요한 프로그램 설치 금지 등을 하도록 하고 있다.

또한, 「개인정보보호법 시행령」 제30조 및 「개인정보보호 내부 관리계획」 제8조에 따라 개인정보취급자는 정보주체의 개인정보 보호를 위해 개인정보의 안전성 확보를 위하여 필요한 조치에 대한 책임이 있다.

정보보안 세부지침 (2023.05.15.)

제73조(단말기 보안)

- ① 개별사용자는 공단에서 지급받은 PC·노트북·휴대폰 등 단말기(이하 “단말기”라 한다) 사용과 관련한 일체의 보안관리 책임을 진다.
- ② 개별사용자는 단말기에 대하여 다음 각 호에 해당하는 보안대책을 준수하여야 한다.
 1. CMOS·로그온·자료 암호화 비밀번호의 정기적 변경 사용
 2. 단말기 작업을 10분 이상 중단시 비밀번호 등을 적용한 화면보호 조치
 3. 최신 백신 소프트웨어 설치
 4. 운영체제 및 응용프로그램에 대한 최신 보안패치 유지
 5. 출처, 유통경로 및 제작자가 불분명한 응용프로그램의 사용 금지
 6. 인터넷을 통해 자료(파일) 획득시 신뢰할 수 있는 인터넷사이트를 활용하고 자료(파일) 다운로드시 최신 백신 소프트웨어로 검사 후 활용
 7. 인터넷 파일공유·메신저·대화방 프로그램 등 업무상 불필요한 프로그램의 설치 금지 및 공유 폴더 삭제
 8. 웹브라우저를 통해 서명되지 않은 액티브-X 등이 다운로드·실행되지 않도록 보안 설정
 9. 내부망과 인터넷망이 분리된 기관의 인터넷 PC에서는 특별한 사유가 없는 한 문서프로그램을 읽기 전용(專用)으로 운용
 10. 그 밖에 국가정보원장이 안전성을 확인하여 배포한 프로그램의 운용 및 보안권고문 이행
- ③ “생략”

개인정보보호법 시행령 (2025.02.25.)

제30조(개인정보의 안전성 확보 조치)

- ① 개인정보처리자는 법 제29조에 따라 다음 각 호의 안전성 확보 조치를 해야 한다.
 - 1~3. “생략”
 4. 개인정보를 안전하게 저장·전송하는데 필요한 다음 각 목의 조치
 - 가. 비밀번호의 일방향 암호화 저장 등 인증정보의 암호화 저장 또는 이에 상응하는 조치
 - 나. 주민등록번호 등 보호위원회가 정하여 고시하는 정보의 암호화 저장 또는 이에 상응하는 조치
 - 다. 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조제1항제1호에 따른 정보통신망을 통하여 정보주체의 개인정보 또는 인증정보를 송신·수신하는 경우 해당 정보의 암호화 또는 이에 상응하는 조치
 - 라. 그 밖에 암호화 또는 이에 상응하는 기술을 이용한 보안조치
 5. “생략”
 6. 개인정보처리시스템 및 개인정보취급자가 개인정보 처리에 이용하는 정보기기에 대해 컴퓨터바이러스, 스파이웨어, 랜섬웨어 등 악성프로그램의 침투 여부를 항시 점검·치료할 수 있도록 하는 등의 기능이 포함된 프로그램의 설치·운영과 주기적 갱신·점검 조치
 7. 개인정보의 안전한 보관을 위한 보관시설의 마련 또는 잠금장치의 설치 등 물리적 조치
 8. 그 밖에 개인정보의 안전성 확보를 위하여 필요한 조치
- ②-③ “생략”

개인정보 보호 내부 관리계획 (2025.05.15.)

제8조(실무총괄자, 분야별책임자, 개인정보취급자의 역할 및 책임 등)

- ①-③ “생략”
- ④ 개인정보취급자의 범위는 정보주체의 개인정보 수집, 보관, 처리, 이용, 제공, 관리 또는 파기 등의 업무를 수행하는 자를 말하고 내부직원 및 외부업체 직원을 포함한다.
- ⑤ 개인정보취급자는 정보주체의 개인정보보호를 위해 다음의 역할 및 책임을 이행한다.
 1. 개인정보보호 활동 참여
 2. 내부 관리계획의 준수 및 이행
 3. 개인정보의 안전성 확보조치 기준 이행
 4. 개인정보파일의 등록 및 변경 신청
 5. 개인정보의 파기
 6. 기타 정보주체의 개인정보보호를 위해 필요한 사항의 이행

3. 감사결과 확인된 문제점

이번 감사기간 동안 광주전남지역본부의 정보보안 및 개인정보보호 관리기준 준수 여부를 확인한 결과, 업무용 PC 내 개인정보를 포함한 ■개 파일이 암호화되어 있지 않은 것으로 확인되었다.

현지조치 사항 광주전남지역본부는 감사기간 동안 개인정보를 포함한 ■개 파일에 대하여 전부 삭제 조치하였으며, 향후 정보보안 강화를 위하여 점검대상자(위규자 포함)를 대상으로 재발방지 교육을 실시하였다.